

CONFIDENTIEL — DIFFUSION RESTREINTE

RAPPORT D'AUDIT DE SÉCURITÉ

Active Directory & surface d'exposition externe

Domaine FINEGIL.local — Reconnaissance externe (Black Box) & audit interne (Grey Box)

CLIENT

BARKENE — Groupe O1C

Sûreté • Incendie • Alarme • Vidéosurveillance

Auditeur	MOMBO Darwin — Mastère Cybersécurité, Sup de Vinci
Commanditaires	A. RODRIGUEZ (RSSI Groupe O1C) — A. LITAUDON (DSI Barkene)
Tuteur entreprise	A. MATEUS (Responsable Support IT)
Périmètre	3 services web exposés + Active Directory FINEGIL.local
Période d'audit	28 mai 2026 – 30 juin 2026
Référentiels	PTES • MITRE ATT&CK • CVSS v4.0 • ANSSI • CIS
Version du rapport	v1.0 — établi le 10 juillet 2026
Classification	Confidentiel — Strictement interne

Contrôle et confidentialité du document

Ce document constitue la restitution formelle de la mission d'audit de sécurité conduite sur l'infrastructure de Barkene (Groupe O1C). Il est établi en complément du mémoire de fin d'études et vise un usage opérationnel par les équipes techniques et de direction du client.

Suivi des versions

Version	Date	Auteur	Objet
v0.1	05/06/2026	MOMBO D.	Consolidation des résultats Black Box
v0.9	29/06/2026	MOMBO D.	Intégration des résultats Grey Box (PingCastle)
v1.0	10/07/2026	MOMBO D.	Version finale diffusable

Diffusion

La diffusion de ce rapport est strictement limitée aux personnes listées ci-dessous. Les données qu'il contient sont classées **Strictement Confidentielles** au titre de l'article 9 de l'accord d'engagement. Toute reproduction ou communication à un tiers non impliqué est proscrite.

Destinataire	Fonction	Usage
A. RODRIGUEZ	RSSI — Groupe O1C	Pilotage de la remédiation
A. LITAUDON	DSI — Barkene	Arbitrage & priorisation
A. MATEUS	Responsable Support IT	Mise en œuvre technique
Jury de soutenance	Sup de Vinci	Évaluation académique

Avertissement — aucune vulnérabilité n'a été exploitée de manière active sur les systèmes de production. L'ensemble des opérations s'est limité à de la reconnaissance non intrusive et à des requêtes LDAP en lecture seule, conformément aux règles d'engagement signées.

Sommaire

Table des matières

Contrôle et confidentialité du document.....	2
Suivi des versions.....	2
Diffusion	2
Sommaire	3
1. Synthèse exécutive.....	5
Indicateurs clés.....	5
Constats majeurs.....	5
Priorités de remédiation	5
2. Périmètre et méthodologie.....	6
2.1 Périmètre de la mission.....	6
Cibles externes (Black Box).....	6
Cibles internes (Grey Box)	6
2.2 Cadre méthodologique.....	6
Outillage	6
2.3 Cadre légal et éthique	6
3. Synthèse des risques	8
Répartition par criticité	8
4. Phase 1 — Reconnaissance externe (Black Box)	9
4.1 Posture TLS et hébergement	9
4.2 Findings détaillés.....	9
4.3 Pistes identifiées vers l'Active Directory	10
5. Phase 2 — Audit interne Active Directory (Grey Box)	11
5.1 Constat global — Domain Risk Level 100/100.....	11
5.2 Comptes à privilèges (100/100)	11
5.3 Anomalies (100/100).....	12
5.4 Objets obsolètes (93/100)	12
5.5 Trusts (1/100)	12
6. Plan de remédiation priorisé	13
6.1 P0 — Urgence (J+0 à J+30)	13
6.2 P1 — Renforcement (J+30 à J+90).....	13
6.3 P2 — Hygiène & détection (J+90 à J+180).....	13
7. Conclusion	14
Annexe A — Éléments de preuve (Black Box)	15
A.1 — emetteur.barkene.fr : analyse Web-Check.....	15
A.2 — emetteur.barkene.fr : HTTP Observatory (MDN)	15

A.3 — emetteur.barkene.fr : scoring de sécurité.....	15
A.4 — www.barkene.fr : HTTP Observatory (MDN).....	17
A.5 — www.barkene.fr : scoring de sécurité	17
A.6 — portail.client.barkene.fr : HTTP Observatory (MDN)	17
Annexe B — Référentiels et outils.....	19

1. Synthèse exécutive

Barkene a mandaté cet audit afin d'évaluer, du point de vue d'un attaquant, la capacité à atteindre puis compromettre son Active Directory (domaine **FINEGIL.local**). La mission s'est déroulée en deux phases progressives : une **reconnaissance externe (Black Box)** depuis Internet, puis un **audit interne (Grey Box)** mené avec un compte utilisateur standard depuis le réseau de l'entreprise.

VERDICT GLOBAL — RISQUE CRITIQUE

L'Active Directory présente un **Domain Risk Level PingCastle de 100/100** (maximum absolu). Un attaquant disposant d'un simple compte interne dispose de plusieurs chemins d'élévation vers les privilèges les plus élevés du domaine, sans recours à une vulnérabilité zéro-day.

Indicateurs clés

Reconnaissance externe	Risque AD (PingCastle)	krbtgt	Chemin DCSync
11 observations 2 findings factuels	100 / 100	inchangé 2 350 jours	Présent (Exchange résiduel)

Constats majeurs

- **krbtgt jamais renouvelé** — le secret Kerberos du domaine n'a pas été changé depuis plus de six ans, exposant le domaine à une attaque Golden Ticket en cas de fuite du hash.
- **Chemin d'élévation vers DCSync** — des droits WriteDacl hérités d'une installation Exchange désinstallée subsistent sur la racine du domaine, permettant à un compte compromis de s'octroyer les droits de réplication.
- **Absence de LAPS et de cloisonnement (Tiering)** — mots de passe d'administrateur local non gérés et 19 comptes à privilèges hors du groupe Protected Users, facilitant le mouvement latéral.
- **Protocoles legacy et hygiène dégradée** — NTLMv1/DES/RC4 encore possibles, LLMNR actif, 41 % de comptes inactifs, un schéma vulnérable résiduel (msExchStorageGroup).

Priorités de remédiation

Quatre actions d'urgence (P0) sont à engager sous 30 jours : double rotation du mot de passe krbtgt, révocation des droits résiduels d'Exchange, mise à zéro du **ms-DS-MachineAccountQuota**. L'objectif défensif est de ramener le score PingCastle sous 50/100. Le plan complet est détaillé en section 5.

2. Périmètre et méthodologie

2.1 Périmètre de la mission

L'audit couvre deux ensembles complémentaires : la surface d'exposition externe (trois services web publics) et l'Active Directory interne du domaine FINEGIL.local.

Cibles externes (Black Box)

Service	IP / hébergement	Protection	Périmètre
www.barkene.fr	92.222.139.190 (OVH)	Aucune (WAF)	IN SCOPE
emetteur.barkene.fr	51.210.106.46 (OVH)	Aucune (WAF)	IN SCOPE
portail.client.barkene.fr	Cloudflare	WAF actif	IN SCOPE
vpn / authentification / preproduct	DNS supprimé	—	HORS SCOPE

Cibles internes (Grey Box)

Contrôleur de domaine	IP	Rôle
SRV-01-ADY-B-01	172.21.204.10	PDC, RID, Infrastructure, Schema, Domain Naming
SRV-21-ADY-B-01	172.20.103.11	Contrôleur secondaire / réplication

2.2 Cadre méthodologique

La mission suit le standard **PTES** (Penetration Testing Execution Standard) pour la structure de l'audit, le framework **MITRE ATT&CK** pour le référencement des techniques, et le système **CVSS v4.0** pour le scoring des vulnérabilités. Les recommandations s'appuient sur les guides **ANSSI** et les benchmarks **CIS**.

Chaque observation est qualifiée selon trois niveaux, afin de distinguer une analyse rigoureuse d'un rapport purement alarmiste :

- **Factuel** — constat vérifié sans ambiguïté ;
- **Conditionnel** — impact dépendant de facteurs d'exploitation non confirmés ;
- **Informatif** — relévé d'information sans impact sécurité direct.

Outillage

Outil	Phase	Usage
WHOIS, dig	Black Box	Reconnaissance DNS, MX/SPF/DMARC
crt.sh, subfinder	Black Box	Découverte passive de sous-domaines (Certificate Transparency)
Web-Check	Black Box	Analyse OSINT (DNS, TLS, headers, ports, technologies)
MDN HTTP Observatory	Black Box	Scoring des en-têtes de sécurité HTTP
testssl.sh 3.2.2	Black Box	Audit TLS/SSL (versions, suites, vulnérabilités)
PingCastle 3.5.0.44	Grey Box	Healthcheck AD — requêtes LDAP en lecture seule
RSAT / PowerShell	Grey Box	Énumération native, vérification des droits

2.3 Cadre légal et éthique

La mission est encadrée par deux accords d'engagement formels signés électroniquement (DocuSign) avant tout démarrage opérationnel : l'accord **Black Box (28 mai 2026)** et l'accord **Grey Box (19 juin 2026)**. Les règles

d'engagement excluent explicitement toute exploitation active, toute attaque par force brute, toute modification de configuration et tout audit d'un AD tiers. Toutes les actions ont été horodatées et docum, en conformité avec la clause de traçabilité.

3. Synthèse des risques

Le tableau ci-dessous consolide l'ensemble des constats des deux phases, classés par criticité. Les identifiants renvoient au détail des sections 4 (externe) et 5 (interne).

ID	Constat	Phase	Criticité	CVSS
AD-KRB	krbtgt inchangé depuis 2 350 jours (Golden Ticket)	Grey	Critique	—
AD-DCSYNC	WriteDacl Exchange résiduel → DCSync	Grey	Critique	—
AD-QUOTA	ms-DS-MachineAccountQuota = 10	Grey	Critique	—
AD-SCHEMA	Schéma vulnérable msExchStorageGroup	Grey	Élevé	—
AD-PU	19 admins hors Protected Users	Grey	Élevé	—
AD-LAPS	Absence de LAPS sur le parc	Grey	Élevé	—
AD-LEGACY	NTLMv1 / DES / RC4 / LLMNR actifs	Grey	Élevé	—
AD-STALE	41 % de comptes inactifs, 427 mdp never-expire	Grey	Moyen	—
EMT-01	Port 21 (FTPES) ouvert — Certificat TLS invalide / non conforme	Black	MOYEN	7.5
EMT-02	Cookie PHPSESSID sans flag Secure	Black	Moyen	6.1
OBS-02	Scripts tiers sans Subresource Integrity	Black	Moyen	5.4
OBS-01	Technologies exposées dans les headers	Black	Moyen	5.3
EMT-03	CSP avec unsafe-inline	Black	Moyen	5.0
EMT-04	Port 8888 WebSocket Ratchet exposé	Black	Moyen	4.0
OBS-03	HSTS absent sur www	Black	Faible	3.7
PRT-01	X-Frame-Options manquant / HSTS partiel	Black	Faible	3.1
OBS-04	SPF soft-fail	Black	Faible	3.1
TLS-01	Suites CBC (LUCKY13 théorique)	Black	Faible	2.2

Répartition par criticité

Critique	Élevé	Moyen	Faible	Total
3	4	7	4	18

4. Phase 1 — Reconnaissance externe (Black Box)

Cette phase simule un attaquant externe ne disposant que du nom de l'entreprise. Elle cartographie la surface d'attaque visible depuis Internet et identifie les vecteurs susceptibles de mener à l'Active Directory. Toutes les actions sont non intrusives (reconnaissance passive et active légère).

4.1 Posture TLS et hébergement

Les trois cibles présentent une configuration TLS solide (grade A à A+ sur testssl.sh) : SSLv2/v3, TLS 1.0/1.1 non offerts, Forward Secrecy et AES-GCM actifs, aucune vulnérabilité Heartbleed/POODLE/ROBOT. Le portail client (portail.client.barkene.fr) présente la meilleure posture, protégé par un WAF Cloudflare, avec CSP, HSTS et cookies sécurisés. Les faiblesses se concentrent sur les en-têtes applicatifs et l'exposition directe de `emetteur.barkene.fr` et `www.barkene.fr` (aucun WAF).

4.2 Findings détaillés

EMT-01 — Port 21 (FTPES sans certificats)

Type : Factuel CVSS v4.0 : 5.3 MITRE : T1589/T1557 Cible : `emetteur.barkene.fr`

Observation — Le port 21 est ouvert et accessible depuis Internet. L'analyse montre que le service prend correctement en charge le chiffrement explicite (**FTPES**). Néanmoins, une erreur critique est levée lors de la négociation TLS : le certificat présenté est invalide (autosigné, expiré ou ne correspond pas au nom de domaine). L'authentification anonyme reste quant à elle refusée.

Analyse — Bien que le protocole FTPES protège théoriquement contre l'écoute passive (contrairement au FTP standard), un certificat non valide casse la chaîne de confiance. Un attaquant en position d'interception réseau (Man-in-the-Middle) pourrait générer son propre certificat frauduleux. Si le client ou le script automatisé qui s'y connecte ignore l'avertissement de sécurité, les identifiants de session risquent d'être capturés.

Recommandation — Si le service est requis pour la production, **remplacez le certificat actuel** par un certificat valide et de confiance (ex: Let's Encrypt ou autorité de certification commerciale) correspondant strictement au sous-domaine `emetteur.barkene.fr`.

- Forcer la configuration du serveur FTP pour **refuser strictement les connexions non chiffrées**.
- Si possible, privilégier une migration vers **SFTP** (port 22), nativement plus robuste et déjà ouvert sur le serveur

EMT-02 — Cookie de session PHPSESSID sans attribut Secure

Type : Factuel CVSS v4.0 : 6.1 MITRE : T1539 Cible : `emetteur.barkene.fr`

Observation — Le cookie de session PHPSESSID est émis sans l'attribut Secure (confirmé par MDN Observatory). Ce cookie identifie la session authentifiée de l'utilisateur.

Analyse — En cas d'accès via une URL HTTP, le cookie serait transmis en clair et interceptable. Le HSTS présent atténue le risque, mais l'absence de Secure reste une non-conformité.

Recommandation — Ajouter les attributs **Secure** et **SameSite=Strict** sur tous les cookies de session.

EMT-03 / EMT-04 — CSP unsafe-inline & port 8888 (WebSocket Ratchet)

Type : Conditionnel / Informatif CVSS v4.0 : 5.0 / 4.0 MITRE : T1059.007 / T1046 Cible : `emetteur.barkene.fr`

Observation — La Content-Security-Policy contient `unsafe-inline` et `data:` dans `script-src`, annulant en partie la protection anti-XSS. Par ailleurs, le port 8888 héberge un service WebSocket Ratchet/0.3.3, probablement lié à l'application ARES.

Recommandation — Remplacer unsafe-inline par des nonces/hashees CSP. Identifier précisément le service du port 8888 et le restreindre par firewall s'il n'a pas vocation à être public.

OBS-01 / OBS-02 / OBS-03 — En-têtes de sécurité www.barkene.fr

Type : Informatif / Conditionnel CVSS v4.0 : 5.3 / 5.4 / 3.7 MITRE : T1592 / T1195.002 / T1557.001 Cible : www.barkene.fr

Observation — Le serveur expose X-Powered-By: PHP/8.2 et Server: OVHcloud (fingerprinting). Des scripts tiers sont chargés sans Subresource Integrity. Le header HSTS est absent (score MDN Observatory 0/100, grade F).

Recommandation — Masquer les bannières de version, ajouter des attributs integrity SRI sur les scripts externes, et publier un header HSTS (max-age ≥ 1 an, includeSubDomains).

OBS-04 — SPF en soft-fail et DMARC absent

Type : Conditionnel CVSS v4.0 : 3.1 MITRE : T1566.002 Cible : barkene.fr (DNS)

Observation — L'enregistrement SPF utilise ~all (soft-fail) et aucune politique DMARC n'est publiée. La présence de spf.protection.outlook.com confirme l'usage de Microsoft 365.

Recommandation — Passer le SPF à -all (hard-fail) et publier un enregistrement DMARC (p=quarantine minimum) pour limiter le spoofing d'emails @barkene.fr.

4.3 Pistes identifiées vers l'Active Directory

Piste	Description	MITRE	Potentiel
Piste 1	FTPES (port 21) — Interception de credentials via MitM si le certificat invalide est ignoré	T1557	MOYEN
Piste 2	Formulaire de login ARES-CMI — énumération de comptes AD via messages d'erreur	T1078 / T1087	Moyen
Piste 3	Port 8888 WebSocket — pivot applicatif potentiel	T1046	À évaluer

5. Phase 2 — Audit interne Active Directory (Grey Box)

Cette phase simule un attaquant interne disposant d'un compte utilisateur standard (équivalent employé), depuis une VM jointe au domaine via VPN. L'audit a été conduit avec **PingCastle 3.5.0.44** en mode healthcheck (requêtes LDAP en lecture seule, impact nul sur la production), le 26 juin 2026.

5.1 Constat global — Domain Risk Level 100/100

Score agrégé : **100 / 100** — maximum absolu de l'échelle. 49 règles de sécurité déclenchées sur 132 évaluées.

Axe	Score	Niveau	Règles
Privileged Accounts	100 / 100	Critique	13
Anomalies	100 / 100	Critique	17
Stale Objects	93 / 100	Élevé	18
Trusts	1 / 100	Faible	1

5.2 Comptes à privilèges (100/100)

Règle	Points	Constat
P-ExchangePrivEsc	15	Exchange Windows Permissions dispose de WriteDacl sur la racine du domaine — vecteur DCSync
P-ServiceDomainAdmin	15	6 comptes Domain Admin avec mot de passe never-expire
P-AdminSDHolder	30	31 utilisateurs avec admincount incohérent
P-Kerberoast	15	≥ 1 membre admin vulnérable au Kerberoasting (T1558.003)
P-ProtectedUsers	10	19 admins NON membres de Protected Users
P-AdminPassword	10	4 admins avec mot de passe > 3 ans
P-SensitiveDelegation	10	13 admins sans flag « sensitive and cannot be delegated »
P-SchemaAdmin	10	2 comptes dans Schema Admins

Vecteur DCSync — le groupe Exchange Windows Permissions conserve un droit WriteDacl sur DC=FINEGIL,DC=local, résidu d'une installation Exchange désinstallée. Un attaquant compromettant un compte membre peut modifier le descripteur de sécurité du domaine pour s'octroyer les droits **Replicating Directory Changes (All)**, nécessaires à une attaque DCSync (T1003.006) qui extrait l'intégralité des hashes de l'annuaire — y compris celui de krbtgt — et compromet la forêt entière.

5.3 Anomalies (100/100)

Alerte Golden Ticket — le mot de passe du compte **krbtgt** n'a pas été changé depuis **2 350 jours** (≈ 6,4 ans). Microsoft recommande une rotation tous les 40 jours.

Règle	Points	Constat
A-Krbtgt	50	krbtgt inchangé depuis 2 350 jours — Golden Ticket possible
A-AdminSDHolder	30	31 users avec admincount détecté
A-DesEnabled	15	1 compte avec DES activé (algorithme cassé)
A-OldAuthenticationProtocols	10	LAN Manager Authentication autorise NTLMv1 / LM — Pass-the-Hash
A-AesNotEnabled	1	14 comptes de service sans AES — Kerberoasting RC4
A-LLMNR	0	Aucune GPO ne désactive LLMNR — résolution spoofable (T1557.001)
A-AuditPS / A-AuditDCDC	0	Audit PowerShell et audit policy des DC incomplets — détection dégradée
A-ASRDefender	0	Règles ASR Defender non en mode Block

5.4 Objets obsolètes (93/100)

Règle	Points	Constat
S-InactiveUser-41pct	10	41 % des comptes inactifs (462 / 1124)
S-PwdNeverExpires	1	427 comptes avec mot de passe never-expire
S-ADRegistration	10	ms-DS-MachineAccountQuota = 10 (valeur par défaut)
S-ADRegistrationSchema	10	Schéma vulnérable msExchStorageGroup (Exchange désinstallé)
S-OS-W10	5	14 PC sur éditions Windows 10/11 non supportées
S-Duplicate	5	1 objet en doublon (\$DUPLICATE-23fd)

Le quota ms-DS-MachineAccountQuota = 10 autorise tout utilisateur authentifié à joindre jusqu'à 10 machines au domaine — vecteur classique d'abus (ex. RBCD). La classe msExchStorageGroup, résidu d'Exchange, permet de manipuler l'attribut possSuperior et devrait être supprimée avec précaution.

5.5 Trusts (1/100)

Aucune vulnérabilité significative, hormis AES non activé sur tous les trusts. Un enregistrement DNS « Trust with Entra ID » suggère une intégration Azure AD Connect active (cohérente avec le SPF Microsoft 365 relevé en Black Box), élargissant le périmètre au-delà du seul AD on-premise.

6. Plan de remédiation priorisé

Les actions sont hiérarchisées en trois vagues. L'objectif défensif est de ramener le score PingCastle de 100/100 à moins de 50/100 en 90 jours.

6.1 P0 — Urgence (J+0 à J+30)

ID	Action	Mise en œuvre	Effort
AD-KRB	Double rotation du mot de passe krbtgt (intervalle 10h)	Script Microsoft New-KrbtgtKeys.ps1	Moyen
AD-DCSYNC	Révoquer le WriteDacl d'Exchange Windows Permissions sur la racine	ADSI Edit / dscls	Faible
AD-QUOTA	Mettre ms-DS-MachineAccountQuota = 0	ADSI Edit + délégation OU dédiée	Faible
EMT-01	Déployer un certificat TLS valide sur le FTPES (ou fermer le port 21)	Renouvellement PKI / Certbot / Équipe SysAdmin	Faible
EMT-02	Ajouter Secure + SameSite sur les cookies	Config PHP applicative	Faible

6.2 P1 — Renforcement (J+30 à J+90)

Axe	Action	Référence
Privilèges	Ajouter les 19 admins à Protected Users ; flag « sensitive » sur 13 comptes	P-ProtectedUsers
Privilèges	Vider/restreindre Schema Admins ; renouveler les mdp > 3 ans	P-SchemaAdmin
LAPS	Déployer LAPS (rotation 30j, ACL de lecture restreintes)	AD-LAPS
Tiering	Implémenter le modèle Tier 0/1/2 + comptes dédiés + PAW	Cloisonnement
Legacy	Forcer NTLMv2 only ; activer AES ; désactiver DES et LLMNR	A-OldAuth / A-LLMNR
Schéma	Auditer puis supprimer la classe msExchStorageGroup (avec précaution)	S-ADRegistrationSchema

6.3 P2 — Hygiène & détection (J+90 à J+180)

Axe	Action	Référence
Comptes	Désactiver/supprimer les 462 comptes inactifs ; revue des 427 never-expire	S-InactiveUser
Postes	Migrer les 14 PC sur éditions non supportées	S-OS-W10
Détection	Audit policy complète des DC + Script Block Logging + ASR en Block	A-AuditDCDC / A-ASR
SIEM	Centraliser les logs (Sentinel/Wazuh) avec règles de corrélation (4625, 4769, 4732...)	Monitoring
Externe	HSTS, SRI, CSP sans unsafe-inline, SPF -all + DMARC	OBS / EMT

KPI de suivi — score PingCastle mesuré mensuellement (healthcheck automatisé). Cible : < 50/100 à J+90, intégrable au tableau de bord RSSI du groupe O1C.

7. Conclusion

L'audit révèle un contraste net entre une surface externe globalement maîtrisée (TLS grade A, WAF Cloudflare sur le portail client, filtrage Sophos, EDR SentinelOne) et un Active Directory en état d'exposition critique. Le score PingCastle de 100/100 n'est pas le fait d'une vulnérabilité isolée mais d'une accumulation de faiblesses systémiques : secret Kerberos jamais renouvelé, droits résiduels d'Exchange ouvrant un chemin DCSync, absence de LAPS et de cloisonnement, protocoles legacy actifs et hygiène des comptes dégradée.

La bonne nouvelle est que ces faiblesses relèvent de la **configuration** et non d'un défaut logiciel : elles sont corrigeables rapidement, sans investissement matériel majeur. Les quatre actions d'urgence (P0) réduisent dès le premier mois l'essentiel du risque de compromission totale du domaine. Le déploiement des vagues P1 et P2 inscrit ensuite Barkene dans une démarche de sécurité durable.

La sécurité d'un Active Directory est un processus continu, jamais un état final. La répétition régulière de cet audit (mesure PingCastle mensuelle) constituera la preuve quantitative de l'efficacité du plan de durcissement.

Annexe A — Éléments de preuve (Black Box)

Captures d'écran horodatées collectées lors de la phase de reconnaissance externe. Les scores PingCastle détaillés (phase Grey Box) figurent en section 5.

A.1 — `emetteur.barkene.fr` : analyse Web-Check

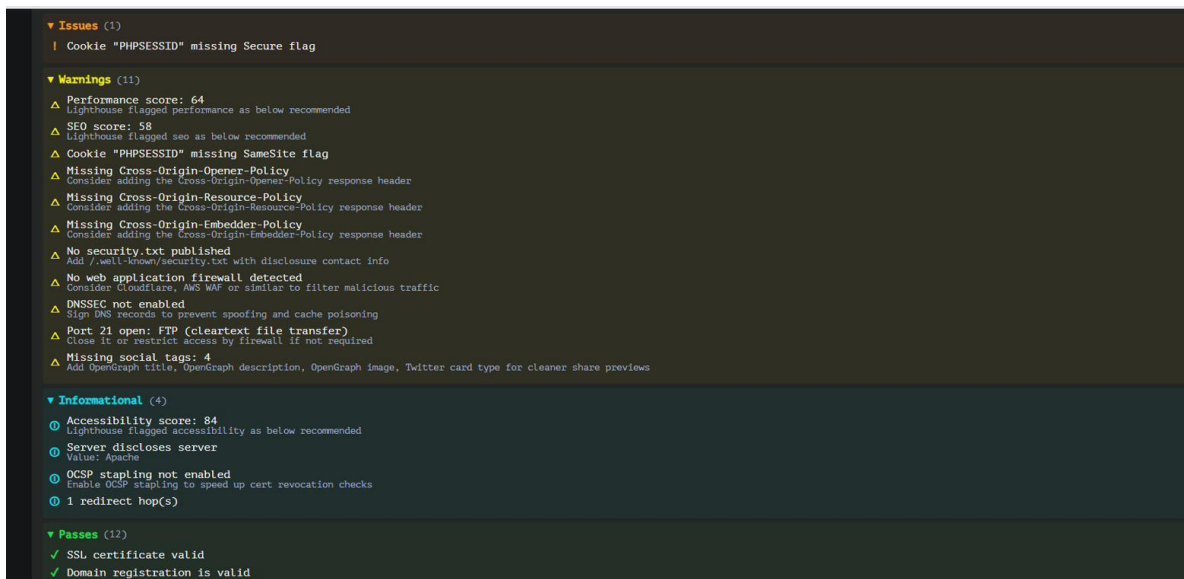


Figure 1 — Web-Check : ports, technologies et en-têtes de `emetteur.barkene.fr`.

A.2 — `emetteur.barkene.fr` : HTTP Observatory (MDN)

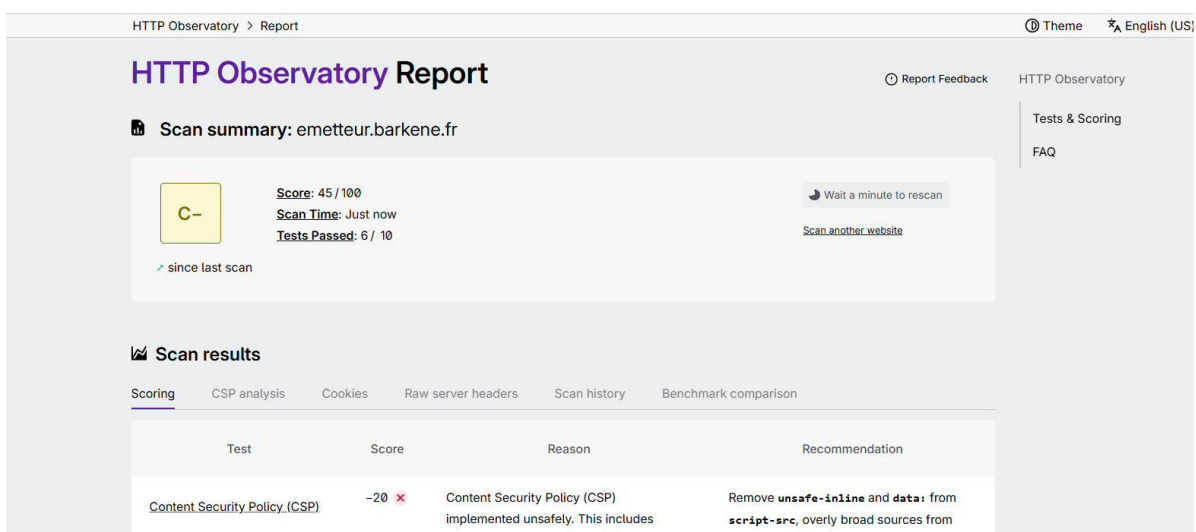


Figure 2 — Score des en-têtes de sécurité HTTP de `emetteur.barkene.fr` (grade C-).

A.3 — `emetteur.barkene.fr` : scoring de sécurité

Scoring			
CSP analysis Cookies Raw server headers Scan history Benchmark comparison			
Test	Score	Reason	Recommendation
Content Security Policy (CSP)	-20 ✖	Content Security Policy (CSP) implemented unsafely. This includes 'unsafe-inline' or data: inside script-src, overly broad sources such as https: inside object-src or script-src, or not restricting the sources for object-src or script-src.	Remove unsafe-inline and data: from script-src, overly broad sources from object-src and script-src, and ensure object-src and script-src are set.
Cookies	-10 ✖	Session cookie set without the Secure flag, but transmission over HTTP prevented by HSTS.	Use Secure flag.
Cross Origin Resource Sharing (CORS)	0 ✔	Content is not visible via cross-origin resource sharing (CORS) files or headers.	None
Redirection	0 ✔	Initial redirection is to HTTPS on same host, final destination is HTTPS	None
Referrer Policy	0* ✔	Referrer-Policy header set to no-referrer, same-origin, strict-origin or strict-origin-when-cross-origin.	None
Strict Transport Security	0 ✔	Strict-Transport-Security header set to	Consider preloading: this requires adding

Figure 3 — Synthèse de scoring de emetteur.barkene.fr.

A.4 — www.barkene.fr : HTTP Observatory (MDN)

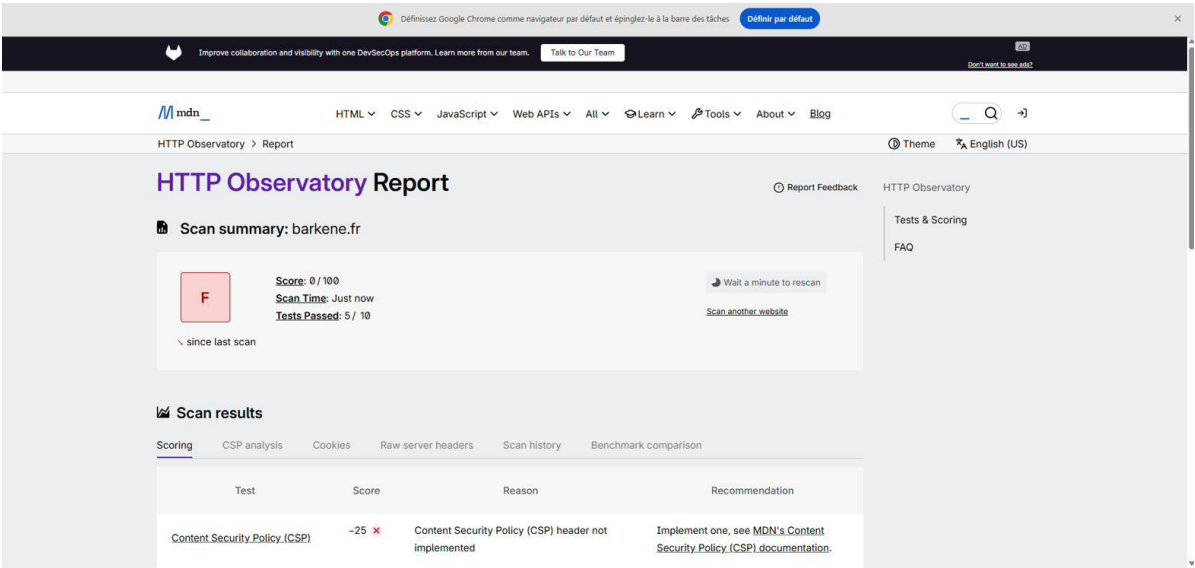


Figure 4 — En-têtes de sécurité HTTP de www.barkene.fr (grade F).

A.5 — www.barkene.fr : scoring de sécurité

Test	Score	Reason	Recommendation	HTTP Obser
Content Security Policy (CSP)	-25 ✖	Content Security Policy (CSP) header not implemented	Implement one, see MDN's Content Security Policy (CSP) documentation .	Tests & Sc FAQ
Cookies	-	No cookies detected	None	
Cross Origin Resource Sharing (CORS)	0 ✔	Content is not visible via cross-origin resource sharing (CORS) files or headers.	None	
Redirection	0 ✔	Initial redirection is to HTTPS on same host, final destination is HTTPS	None	
Referrer Policy	-	Referrer-Policy header not implemented.	Set to strict-origin-when-cross-origin at a minimum.	
Strict Transport Security (HSTS)	-20 ✖	Strict-Transport-Security header not implemented.	Add HSTS. Consider rolling out with shorter periods first (as suggested on https://hstspreload.org/).	
Subresource Integrity	-50 ✖	Subresource Integrity (SRI) not implemented, and external scripts are loaded over HTTP or they use protocol-relative URLs via <code>src="//..."</code> .	Load external scripts over HTTPS, and add SRI to them.	
X-Content-Type-Options	-5 ✖	X-Content-Type-Options header not	Set to nosniff .	

Figure 5 — Synthèse de scoring de www.barkene.fr.

A.6 — portail.client.barkene.fr : HTTP Observatory (MDN)

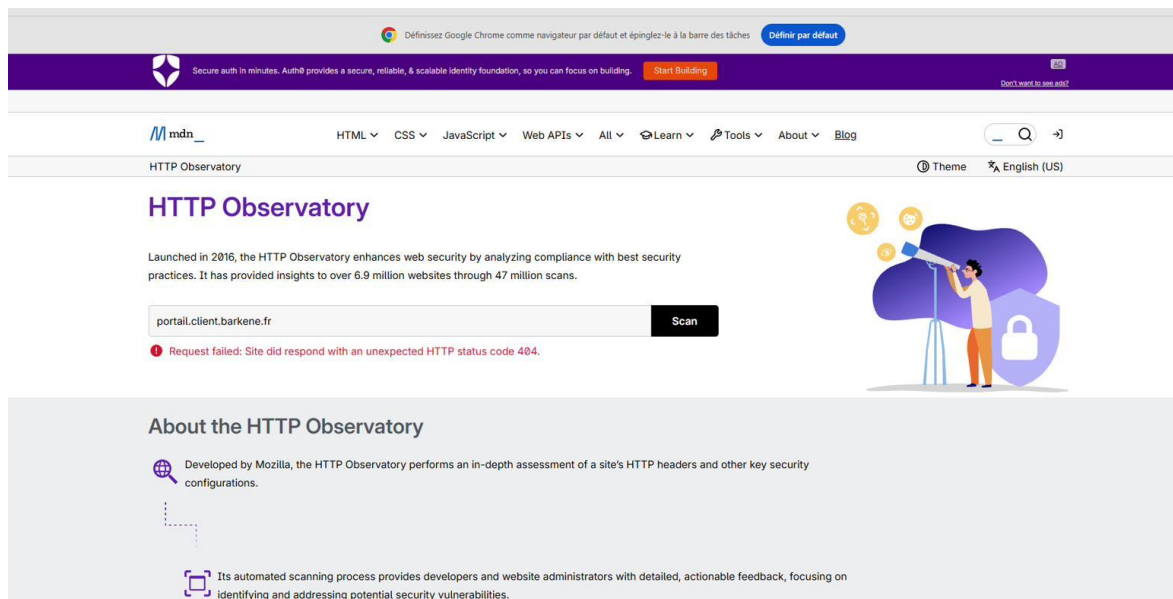


Figure 6 — En-têtes du portail client (protégé par WAF Cloudflare).

Annexe B — Référentiels et outils

Référentiel	Usage dans la mission
PTES	Structuration de l'audit en phases (reconnaissance → audit interne → restitution)
MITRE ATT&CK	Référencement des techniques d'attaque associées à chaque constat
CVSS v4.0	Scoring de sévérité des vulnérabilités externes
ANSSI	Guides de recommandations (durcissement AD, TLS, journalisation)
CIS Benchmarks	Référentiel de configuration sécurisée Windows / AD
PingCastle	Healthcheck AD — scoring de maturité (Privileged, Anomalies, Stale, Trusts)

Fin du rapport — document confidentiel, diffusion restreinte aux destinataires listés en page 2.